

Pertemuan 12: Keamanan Cloud & Virtualisasi

Shared Responsibility • CASB • IAM Cloud • Enkripsi Cloud • DLP • Container Security • Cloud Security Posture

Mata Kuliah	Keamanan Data	Pertemuan	12 dari 16
Durasi	150 menit (3 SKS)	Metode	Ceramah, Demo Cloud, Lab Konfigurasi IAM
Prasyarat	Pertemuan 1–11 (terutama autentikasi, kriptografi, manajemen risiko)	Tugas	Konfigurasi IAM cloud (lab AWS/Azure/GCP)

A. Capaian Pembelajaran Pertemuan

Setelah mengikuti pertemuan ini, mahasiswa diharapkan mampu:

1. Menjelaskan model layanan cloud (IaaS, PaaS, SaaS) dan implikasinya terhadap keamanan
2. Memahami dan menerapkan prinsip Shared Responsibility Model dalam konteks keamanan cloud
3. Merancang kebijakan Identity & Access Management (IAM) yang aman di lingkungan cloud
4. Menjelaskan fungsi Cloud Access Security Broker (CASB) dan kapan menggunakannya
5. Menerapkan enkripsi data di lingkungan cloud (at rest, in transit, key management)
6. Memahami konsep Data Loss Prevention (DLP) dan implementasinya di cloud
7. Menjelaskan ancaman keamanan spesifik pada container dan cara mitigasinya

B. Model Layanan Cloud & Implikasi Keamanan

1.1 Tiga Model Layanan Cloud

Memahami model layanan cloud adalah fondasi dari keamanan cloud. Setiap model menentukan batas tanggung jawab antara penyedia cloud dan pengguna, yang secara langsung mempengaruhi kontrol keamanan apa yang harus diimplementasikan oleh masing-masing pihak.

Model	IaaS Infrastructure as a Service	PaaS Platform as a Service	SaaS Software as a Service
Definisi	Penyedia menyediakan virtualisasi, server, storage, jaringan. Pengguna kelola OS ke atas.	Penyedia menyediakan platform runtime, middleware, database. Pengguna fokus pada aplikasi & data.	Penyedia menyediakan aplikasi siap pakai lewat internet. Pengguna hanya menggunakan.
Contoh	AWS EC2, Azure VM, Google Compute Engine, DigitalOcean Droplet	AWS Elastic Beanstalk, Google App Engine, Heroku, Azure App Service	Gmail, Microsoft 365, Salesforce, Zoom, Slack, Google Workspace
Kontrol Pengguna	OS, middleware, runtime, aplikasi, data, autentikasi, network config (Security Group)	Aplikasi, data, autentikasi pengguna, konfigurasi platform terbatas	Hanya konfigurasi pengguna & data yang dimasukkan ke dalam aplikasi

Kontrol Penyedia	Fisik, jaringan, hypervisor, storage hardware	Fisik + OS + runtime + middleware + jaringan	Segalanya kecuali data & akses pengguna — keamanan hampir sepenuhnya di penyedia
Risiko Utama	Misconfiguration OS & firewall, unpatched VM, exposed ports	Insecure app code, misconfigured DB, dependency vulnerability	Akun dibobol, data leak oleh insider, shadow IT, third-party breach

C. Shared Responsibility Model

2.1 Konsep Shared Responsibility

Shared Responsibility Model adalah kerangka yang mendefinisikan pembagian tanggung jawab keamanan antara penyedia cloud (Cloud Service Provider / CSP) dan pelanggan cloud. Kesalahpahaman tentang model ini adalah salah satu penyebab utama insiden keamanan cloud — pelanggan sering mengira penyedia bertanggung jawab atas lebih banyak hal dari yang sebenarnya.



Miskonsepsi Umum

Banyak organisasi berasumsi: "Karena data saya di cloud AWS/Azure/GCP yang besar dan terpercaya, berarti data saya otomatis aman." SALAH. AWS, Azure, GCP bertanggung jawab atas keamanan INFRASTRUKTUR cloud (hardware, hypervisor, fasilitas fisik). Keamanan DATA dan APLIKASI yang Anda letakkan di cloud TETAP menjadi tanggung jawab Anda. Analogi: Hotel bertanggung jawab atas keamanan gedung dan kunci kamar, tapi bukan bertanggung jawab atas apa yang Anda tinggalkan di dalam kamar.

2.2 Tabel Tanggung Jawab per Model Layanan

Komponen Keamanan	On-Premise	IaaS	PaaS	SaaS
Keamanan Fasilitas Fisik (DC)	CSP	CSP	CSP	CSP
Keamanan Hardware & Jaringan Fisik	CSP	CSP	CSP	CSP
Virtualisasi / Hypervisor	CSP	CSP	CSP	CSP
Sistem Operasi (OS)	CSP	Pelanggan	CSP	CSP
Middleware & Runtime	CSP	Pelanggan	Pelanggan	CSP
Enkripsi & Keamanan Data	CSP	Pelanggan	Pelanggan	Bersama
Konfigurasi Firewall / Network	CSP	Pelanggan	Bersama	CSP
Manajemen Identitas & Akses	CSP	Pelanggan	Pelanggan	Bersama
Kode Aplikasi	CSP	Pelanggan	Pelanggan	CSP
Data Pelanggan & Klasifikasinya	CSP	Pelanggan	Pelanggan	Pelanggan

Keterangan: CSP = tanggung jawab Cloud Service Provider | Pelanggan = tanggung jawab pengguna | Bersama = tanggung jawab dibagi

2.3 Implikasi Praktis Shared Responsibility

- Selalu baca dokumentasi Shared Responsibility Model dari CSP Anda (AWS, Azure, GCP masing-masing punya versi berbeda)
- Identifikasi 'your responsibility' untuk setiap layanan cloud yang digunakan — berbeda untuk EC2 vs RDS vs S3
- Jangan berasumsi fitur keamanan CSP aktif secara default — banyak yang harus dikonfigurasi secara eksplisit
- Gunakan Cloud Security Posture Management (CSPM) untuk audit konfigurasi cloud secara otomatis
- Enkripsi data sebelum menaruhnya di cloud (client-side encryption) untuk kontrol maksimum

D. Identity & Access Management (IAM) di Cloud

3.1 Konsep IAM Cloud

IAM cloud adalah layanan yang mengelola siapa (identitas) yang dapat melakukan apa (akses) terhadap sumber daya cloud mana (resource). IAM adalah garis pertahanan pertama dan paling kritis dalam keamanan cloud — lebih dari 80% insiden keamanan cloud melibatkan kredensial yang dikompromikan atau konfigurasi IAM yang salah.

Komponen IAM	Definisi	Contoh
Identitas (Identity / Principal)	Entitas yang meminta akses ke sumber daya. Bisa berupa manusia atau sistem/mesin.	User (manusia), Service Account (aplikasi), Role (entitas yang dapat diasumsikan), Grup (kumpulan user)
Autentikasi (Authentication)	Proses memverifikasi bahwa identitas adalah siapa yang diklaim. Faktor pertama dan wajib.	Password + MFA, SSO/SAML, API Key, Certificate-based auth, OIDC/OAuth 2.0
Otorisasi (Authorization)	Proses menentukan aksi apa yang boleh dilakukan identitas yang sudah terotentikasi.	IAM Policy (JSON), Role-Based Access, Attribute-Based Access, Permission Boundary
Kebijakan (Policy)	Dokumen yang mendefinisikan izin secara eksplisit: sumber daya apa, aksi apa, kondisi apa.	AWS IAM Policy JSON, Azure RBAC Role Definition, GCP IAM Policy Binding
Peran (Role)	Kumpulan izin yang dapat diasumsikan sementara oleh identitas yang memenuhi syarat.	AWS IAM Role (untuk EC2, Lambda), Azure Managed Identity, GCP Service Account

3.2 Prinsip IAM yang Aman — Best Practices

Prinsip	Penjelasan & Implementasi
Least Privilege (Wajib!)	Berikan izin minimum yang diperlukan. Hindari wildcard (*) pada action atau resource. Review dan kurangi izin secara berkala. Gunakan Access Analyzer untuk identifikasi izin berlebih.
Wajibkan MFA untuk Semua Akun	Aktifkan MFA untuk root account / global admin SEGERA. Wajibkan MFA untuk semua IAM user terutama yang memiliki akses konsol. Gunakan hardware MFA key untuk akun privileged.
Jangan Gunakan Root / Global Admin Sehari-hari	Root account AWS / Global Admin Azure hanya untuk tugas administratif darurat. Buat IAM user terpisah untuk operasional sehari-hari. Kunci root account dengan MFA hardware.

Gunakan Roles, Bukan Long-Term Credentials	Untuk aplikasi dan service, gunakan IAM Role / Managed Identity alih-alih access key statis yang tidak kedaluwarsa. Role menghasilkan temporary credentials yang lebih aman.
Rotasi Credential Secara Berkala	Rotasi access key setiap 90 hari. Hapus access key yang tidak digunakan lebih dari 90 hari. Gunakan AWS Secrets Manager / Azure Key Vault untuk menyimpan dan merotasi secret otomatis.
Pisahkan Akun / Subscription per Lingkungan	Gunakan akun AWS / subscription Azure terpisah untuk Dev, Staging, dan Production. Hinder lateral movement jika salah satu lingkungan dikompromikan.
Aktifkan CloudTrail / Audit Log	Aktifkan logging semua aktivitas IAM: siapa login, aksi apa dilakukan, dari IP mana. Simpan log di S3/storage yang terpisah dan dilindungi dari penghapusan.
Terapkan Permission Boundary	Tetapkan batas maksimum izin yang bisa dimiliki entitas, bahkan jika admin mencoba memberikan lebih. Penting untuk multi-tenant dan delegasi administrasi.

3.3 Perbandingan IAM di Tiga CSP Utama

Fitur / Konsep	AWS IAM	Azure Active Directory (Entra ID)	Google Cloud IAM
Identitas Utama	IAM Users, Groups, Roles	Users, Groups, Service Principals, Managed Identity	Google Accounts, Service Accounts, Groups
Model Autorisasi	Identity-based & Resource-based Policy (JSON)	Role-Based Access Control (RBAC) dengan Role Definitions	Resource-level IAM Bindings dengan Roles
Akses Mesin/App	IAM Role with Instance Profile / OIDC	Managed Identity (System/User-assigned)	Service Account + Workload Identity Federation
Federasi Identitas	IAM Identity Center, SAML 2.0, OIDC	Azure AD B2B, SAML, OIDC, WS-Fed	Cloud Identity, SAML, OIDC, Workforce Identity
Audit Log	AWS CloudTrail	Azure Monitor Activity Log + Sign-in Log	Cloud Audit Logs (Admin Activity, Data Access)
Manajemen Secret	AWS Secrets Manager, Parameter Store	Azure Key Vault	Secret Manager, Cloud KMS
Analisis Akses	IAM Access Analyzer	Azure AD Access Reviews, Privileged Identity Management	IAM Recommender, Policy Analyzer

3.4 Contoh IAM Policy — Prinsip Least Privilege (AWS)

 Contoh Policy	// ❌ BURUK — Izin terlalu luas (admin penuh pada semua S3 bucket) { "Effect": "Allow", "Action": "s3:*", "Resource": "*" } // ✅ BAIK — Hanya izinkan baca objek pada bucket spesifik { "Effect": "Allow", "Action": ["s3:GetObject", "s3:ListBucket"], "Resource": ["arn:aws:s3:::my-app-data-bucket", "arn:aws:s3:::my-app-data-bucket/*"], "Condition": { "IpAddress": { "aws:SourceIp": "203.0.113.0/24" } } }
---	--

E. Cloud Access Security Broker (CASB)

4.1 Definisi & Fungsi CASB

CASB (diucapkan "CAS-bee") adalah solusi keamanan yang berfungsi sebagai perantara (broker) antara pengguna cloud dan penyedia layanan cloud. CASB memberikan visibilitas, kontrol, dan perlindungan terhadap penggunaan layanan cloud — baik yang disetujui (sanctioned) maupun tidak disetujui (unsanctioned / shadow IT) oleh organisasi.

Empat Pilar CASB	Fungsi	Contoh Implementasi
1. Visibility (Visibilitas)	Menemukan dan memetakan semua layanan cloud yang digunakan karyawan, termasuk shadow IT yang tidak diketahui IT department.	Deteksi karyawan menggunakan Dropbox personal atau WeTransfer untuk transfer data perusahaan
2. Compliance (Kepatuhan)	Memastikan penggunaan cloud memenuhi kebijakan keamanan dan regulasi (GDPR, PCI-DSS, HIPAA). Identifikasi data sensitif di cloud.	Deteksi dokumen yang mengandung nomor kartu kredit diupload ke Google Drive personal
3. Data Security (Keamanan Data)	Mencegah kebocoran data sensitif (DLP). Enkripsi data di cloud. Kontrol berbagi file dan akses berlebih.	Blokir upload file yang mengandung NIK ke layanan cloud yang tidak disetujui
4. Threat Protection (Proteksi Ancaman)	Mendeteksi akun yang dikompromikan, malware di cloud storage, dan perilaku anomali pengguna (UEBA).	Alert ketika pengguna login dari dua negara berbeda dalam waktu 1 jam (impossible travel)

4.2 Mode Deployment CASB

Mode	Cara Kerja	Kelebihan / Kekurangan
API Mode (Out-of-band)	CASB terhubung ke API cloud service (Office 365, Salesforce, AWS) untuk memantau dan menerapkan kebijakan pada data yang sudah tersimpan.	Tidak mempengaruhi latensi, tidak butuh perubahan jaringan / Tidak dapat memblokir secara real-time, hanya deteksi setelah kejadian
Proxy Mode (Forward Proxy)	Traffic pengguna diarahkan melalui CASB proxy sebelum ke cloud. Membutuhkan konfigurasi di perangkat pengguna.	Kontrol real-time, bisa blokir upload / Membutuhkan agent atau konfigurasi PAC file di semua perangkat
Reverse Proxy Mode	CASB ditempatkan di depan aplikasi cloud. Traffic dari internet ke cloud melewati CASB. Tidak butuh agent.	Cocok untuk BYOD & unmanaged devices / Hanya untuk akses berbasis browser, tidak untuk aplikasi native

4.3 CASB vs Solusi Keamanan Lainnya

Solusi	Fokus Utama	Kapan Digunakan
Firewall Tradisional	Kontrol traffic berdasarkan IP & port di perimeter jaringan on-premise	Sudah tidak cukup sendiri — tidak memahami konteks cloud
CASB	Visibilitas & kontrol penggunaan cloud, perlindungan data di SaaS	Organisasi yang menggunakan banyak SaaS & ingin kontrol data

SASE / SSE	Gabungan CASB + SWG + ZTNA + FWaaS dalam satu platform cloud-native	Organisasi yang ingin unified security platform untuk cloud era
CSPM	Audit dan remediasi misconfiguration di infrastruktur cloud (IaaS)	Untuk mengaudit konfigurasi S3, VM, database di AWS/Azure/GCP

F. Enkripsi Data di Cloud

5.1 Enkripsi Data at Rest di Cloud

Enkripsi data saat disimpan di cloud adalah keharusan untuk data sensitif. Pertanyaan kuncinya: siapa yang memegang kunci enkripsi? Ini menentukan tingkat kontrol dan privasi yang Anda miliki terhadap data Anda.

Model Enkripsi	Siapa Pegang Kunci?	Cara Kerja	Tingkat Kontrol
CSP-Managed Encryption (SSE-S3, Azure Storage Encryption)	Penyedia Cloud (CSP)	CSP mengenkripsi dan mendekripsi data secara transparan. Pengguna tidak perlu melakukan apa-apa.	Rendah — CSP berpotensi akses data
Customer-Managed Keys (AWS SSE-KMS, Azure CMK)	Pelanggan — dikelola via KMS cloud	Pelanggan buat dan kontrol kunci di Cloud KMS (AWS KMS, Azure Key Vault, GCP Cloud KMS). CSP gunakan kunci milik pelanggan.	Sedang-Tinggi — pelanggan kontrol kunci
Customer-Provided Keys (AWS SSE-C, Azure SSE-C)	Pelanggan sepenuhnya	Pelanggan mengirimkan kunci saat setiap request baca/tulis. CSP tidak menyimpan kunci.	Tinggi — CSP tidak pernah menyimpan kunci
Client-Side Encryption	Pelanggan sepenuhnya	Data dienkripsi di sisi klien SEBELUM dikirim ke cloud. CSP hanya menerima data terenkripsi yang tidak bisa dibaca.	Tertinggi — CSP tidak bisa baca data sama sekali

5.2 Key Management Service (KMS) — Manajemen Kunci Enkripsi

Key Management Service (KMS) adalah layanan terkelola untuk membuat, menyimpan, dan mengelola kunci enkripsi kriptografi. KMS adalah komponen kritis dalam strategi enkripsi cloud karena keamanan enkripsi hanya sebaik pengelolaan kuncinya.

Fitur KMS	AWS KMS	Azure Key Vault	GCP Cloud KMS
Enkripsi Simetris	AES-256 (default)	AES-256	AES-256 / AES-128
Enkripsi Asimetris	RSA 2048/3072/4096, ECC	RSA, EC	RSA 2048/3072/4096, EC
Hardware Security	CloudHSM (dedicated)	Managed HSM	Cloud HSM
Key Rotation	Otomatis tahunan	Dapat dikonfigurasi	Otomatis / manual

Audit Log	CloudTrail	Key Vault Audit Log	Cloud Audit Logs
Biaya	Per API call	Per operation + storage	Per key version

5.3 Enkripsi Data in Transit di Cloud

- TLS 1.3 wajib untuk semua koneksi antara klien dan layanan cloud — selalu verifikasi tidak ada fallback ke TLS 1.0/1.1
- Aktifkan HTTPS Enforcement pada semua endpoint API gateway, load balancer, dan CDN
- Gunakan mTLS (Mutual TLS) untuk komunikasi service-to-service dalam cluster Kubernetes atau microservices
- AWS: aktifkan 'Enforce HTTPS' di S3 bucket policy dan API Gateway. Azure: aktifkan HTTPS-only di Storage Account dan App Service
- VPN atau Private Link / PrivateEndpoint untuk koneksi dari on-premise ke cloud — jangan kirim data sensitif via internet publik
- Certificate management: gunakan AWS Certificate Manager / Azure App Service Certificate untuk manajemen TLS certificate otomatis

G. Data Loss Prevention (DLP) di Cloud

6.1 Definisi & Fungsi DLP

Data Loss Prevention (DLP) adalah seperangkat teknologi dan proses yang bertujuan memastikan data sensitif tidak keluar dari lingkungan yang diizinkan tanpa otorisasi — baik secara tidak sengaja (human error) maupun disengaja (pencurian data, insider threat). DLP mengidentifikasi, memantau, dan melindungi data sensitif di mana pun data tersebut berada.

Jenis DLP	Cara Kerja	Contoh Penerapan
Network DLP (Data in Transit)	Memantau dan mengontrol data yang bergerak melalui jaringan. Dapat memblokir email atau upload yang mengandung data sensitif.	Blokir email yang mengandung nomor kartu kredit. Alert ketika file database dikirim ke alamat eksternal.
Endpoint DLP (Data in Use)	Berjalan sebagai agent di perangkat pengguna. Mengontrol aktivitas di endpoint: copy ke USB, screenshot, print, upload ke cloud.	Blokir copy data ke USB drive. Larang screenshot konten terklasifikasi. Watermark dokumen sensitif saat dicetak.
Cloud DLP (Data at Rest)	Scan data yang tersimpan di cloud storage (S3, SharePoint, OneDrive) untuk mengidentifikasi dan melindungi data sensitif.	Scan semua file di S3 bucket untuk temukan NIK atau data kartu. Enkripsi otomatis atau beri label data sensitif yang ditemukan.
Email DLP	Inspeksi email keluar untuk mencegah pengiriman data sensitif via email tanpa otorisasi.	Blokir email dengan lampiran spreadsheet yang mengandung > 100 NIK. Wajibkan enkripsi email yang mengandung data medis.

6.2 Teknik Identifikasi Data Sensitif dalam DLP

- Pattern Matching / Regex: Mendeteksi pola seperti nomor kartu kredit (16 digit), NIK (16 digit), nomor NPWP, email, nomor telepon
- Keyword Dictionary: Daftar kata kunci sensitif seperti 'CONFIDENTIAL', 'RAHASIA', 'password', 'rekam medis'

- Document Fingerprinting: Hash dokumen template sensitif dan deteksi dokumen serupa secara otomatis
- Machine Learning Classification: Model ML yang dilatih untuk mengklasifikasikan konten berdasarkan konten (bukan hanya pola)
- Exact Data Match (EDM): Cocokkan data dengan database referensi (misal: daftar NIK karyawan aktual)

6.3 Tindakan DLP saat Data Sensitif Terdeteksi

Tindakan	Deskripsi	Kapan Digunakan
Monitor (Log Only)	Catat kejadian tanpa mengambil tindakan apapun. Mode observasi awal.	Fase kalibrasi DLP, mengumpulkan baseline data
Notify (Alert)	Kirim notifikasi ke pengguna, manajer, atau tim keamanan. Tidak blokir.	Ketika false positive masih tinggi, edukasi pengguna
Encrypt	Enkripsi otomatis data sensitif yang ditemukan atau yang akan dikirim.	Email dengan data sensitif ke pihak eksternal yang diizinkan
Quarantine	Isolasi file yang mengandung data sensitif untuk review oleh admin.	File di cloud storage yang mengandung data sensitif tidak diharapkan
Block	Blokir aksi sepenuhnya: upload, email, copy ke USB tidak dapat dilakukan.	Ketika policy sudah matang dan false positive rendah
Watermark	Tambahkan watermark invisible atau visible pada dokumen sensitif.	Dokumen rahasia yang perlu di-track asal muasal bocornya

H. Keamanan Container & Kubernetes

7.1 Konsep Container & Ancaman Keamanan

Container adalah unit software yang mengemas kode aplikasi beserta semua dependensinya dalam satu paket yang dapat berjalan konsisten di berbagai lingkungan. Docker adalah platform container paling populer, sementara Kubernetes (K8s) adalah platform orkestrasi container yang paling banyak digunakan. Teknologi ini membawa manfaat besar, namun juga surface attack baru yang perlu dipahami.

Ancaman Keamanan Container	Deskripsi	Dampak
Vulnerable Container Image	Image Docker yang dibangun dari base image usang atau berisi library dengan kerentanan CVE yang sudah diketahui.	Penyerang dapat mengeksploitasi kerentanan library untuk mendapatkan akses ke container
Secrets dalam Image / Env Var	Credential, API key, atau password disimpan langsung dalam Dockerfile, environment variable, atau kode aplikasi.	Siapa pun yang mendapat akses ke image dapat mengekstrak credential sensitif
Container Escape	Penyerang yang berhasil masuk ke container mencoba keluar dari isolasi container untuk mengakses host OS.	Kompromi seluruh host dan semua container lain yang berjalan di host yang sama

Overprivileged Container	Container dijalankan sebagai root atau dengan flag --privileged yang memberikan akses hampir penuh ke host.	Container escape menjadi sangat mudah; akses penuh ke host jika berhasil escape
Insecure Kubernetes Config	Kubernetes API server yang terbuka ke internet, RBAC tidak dikonfigurasi, dashboard tidak diamankan.	Attacker dapat mengontrol seluruh cluster Kubernetes dari internet
Malicious/Untrusted Images	Menggunakan image Docker dari registri tidak terpercaya yang mungkin mengandung backdoor atau malware.	Supply chain attack — malware berjalan langsung dalam production environment
Lateral Movement via Network	Container dalam cluster dapat berkomunikasi bebas satu sama lain tanpa pembatasan.	Jika satu container disusupi, penyerang dapat menyerang container dan service lain dalam cluster

7.2 Container Security Best Practices — "4C" Security

 Model 4C Security	Keamanan cloud-native menggunakan model '4C': Cloud → Cluster → Container → Code. Setiap lapisan harus diamankan secara independen dan saling melengkapi: Cloud: IAM, VPC, security group, KMS Cluster: Kubernetes RBAC, network policy, API server hardening Container: Non-root user, read-only filesystem, resource limits Code: Secure coding, dependency scanning, secrets management
---	--

Praktik Keamanan	Implementasi Detail
Gunakan Base Image Minimal	Pakai image minimal seperti Alpine Linux atau distroless. Semakin sedikit komponen dalam image, semakin kecil attack surface. Jangan gunakan 'latest' tag — pin ke versi spesifik.
Scan Image Secara Otomatis	Integrasikan vulnerability scanner dalam CI/CD pipeline: Trivy, Snyk, Clair, atau AWS ECR Scanning. Blokir deployment jika ditemukan CVE kritis yang belum di-patch.
Jangan Jalankan sebagai Root	Tambahkan 'USER nonroot' dalam Dockerfile. Tentukan runAsNonRoot: true dan runAsUser di Kubernetes Pod Security Context. Root dalam container dapat menjadi root di host jika terjadi escape.
Secrets Management	Jangan simpan secret dalam environment variable atau Dockerfile. Gunakan: Kubernetes Secrets + enkripsi etcd, HashiCorp Vault, AWS Secrets Manager, atau External Secrets Operator.
Implementasi Network Policy	Kubernetes Network Policy membatasi traffic antar pod. Terapkan default-deny policy, lalu izinkan hanya komunikasi yang diperlukan. Gunakan Calico atau Cilium untuk implementasi.
Terapkan Pod Security Standards	Gunakan Kubernetes Pod Security Admission untuk enforce Restricted atau Baseline policy: larang privileged container, larang hostNetwork, wajibkan non-root, batasi capabilities.
Immutable Container	Set readOnlyRootFilesystem: true di security context. Container tidak dapat menulis ke filesystem — jika malware masuk, tidak bisa memodifikasi binary atau konfigurasi sistem.
Runtime Security Monitoring	Gunakan Falco untuk mendeteksi perilaku anomali container di runtime: shell terbuka di container, akses file sensitif, network connection mencurigakan, privilege escalation.

I. Cloud Security Posture Management (CSPM)

CSPM adalah kategori solusi keamanan yang terus-menerus memantau, menilai, dan memperbaiki konfigurasi keamanan infrastruktur cloud. CSPM mengidentifikasi misconfiguration — salah satu penyebab utama insiden keamanan cloud — sebelum dapat dieksploitasi.

8.1 Misconfiguration Cloud yang Paling Umum

Misconfiguration	Deskripsi	Contoh Insiden Nyata
S3 Bucket / Blob Storage Publik	Storage bucket dikonfigurasi public-read atau public-write tanpa disadari, mengekspos data sensitif ke seluruh internet.	Jutaan file rekam medis, database pelanggan, dan data kartu kredit terekspos akibat S3 bucket yang terbuka publik
Security Group / Firewall Terlalu Longgar	Port SSH (22), RDP (3389), atau database (3306, 5432) terbuka ke seluruh internet (0.0.0.0/0).	Database diakses langsung dari internet, server diretas via SSH brute force
MFA Tidak Aktif pada Root/Admin	Akun root AWS atau Global Admin tanpa MFA menjadi target serangan credential stuffing.	Akun root dibobol, attacker menghapus semua resource atau menambang cryptocurrency
CloudTrail / Audit Log Tidak Aktif	Tidak ada logging aktivitas API dan manajemen. Insiden tidak dapat diinvestigasi.	Breach terjadi tapi tidak bisa diinvestigasi karena tidak ada log — compliance violation
Enkripsi Tidak Aktif	S3 bucket, EBS volume, RDS database tidak dienkripsi meskipun menyimpan data sensitif.	Jika storage fisik diakses, data dapat dibaca langsung tanpa hambatan enkripsi
IAM User dengan Akses Admin Berlebih	Banyak user memiliki AdministratorAccess atau policy wildcard (*) yang jauh melebihi kebutuhan.	Credential satu karyawan dikompromikan → attacker mendapat akses penuh ke seluruh cloud account

8.2 Tools CSPM Populer

Tool / Layanan	Fungsi Utama	Platform
AWS Security Hub	Dashboard terpusat keamanan AWS: agregasi findings dari GuardDuty, Inspector, Macie, dan mitra. Benchmark CIS AWS.	AWS
AWS Config	Audit konfigurasi resource AWS secara kontinyu. Buat compliance rules dan remediasi otomatis.	AWS
Microsoft Defender for Cloud	CSPM + workload protection untuk Azure, AWS, GCP. Secure Score, rekomendasi, threat detection.	Multi-cloud
Google Security Command Center	Visibilitas keamanan aset GCP, deteksi misconfiguration, threat detection, compliance reporting.	GCP
Wiz	CSPM multi-cloud dengan graph-based analysis. Identifikasi attack path dan risiko kritis. Agentless.	Multi-cloud

Prisma Cloud (Palo Alto)	Platform CNAPP lengkap: CSPM + CWPP + CIEM + container security + IaC scanning.	Multi-cloud
Prowler / ScoutSuite	Open source security auditing tools untuk AWS, Azure, GCP. Cocok untuk assessment mandiri.	Multi-cloud

J. Cloud Security Well-Architected Framework

Semua CSP besar menerbitkan framework arsitektur terbaik sebagai panduan merancang sistem cloud yang aman, andal, dan efisien. Pilar keamanan adalah salah satu yang paling kritis.

Area Keamanan	AWS WAF — Security Pillar	Azure WAF — Security	GCP WAF — Security
Identitas	Strong identity foundation, enable traceability	Identity management, separation of duties	Identity and access management
Deteksi	Enable traceability (CloudTrail, GuardDuty)	Monitor and detect threats (Defender)	Detect threats (Security Command Center)
Perlindungan Infrastruktur	Protect infrastructure (VPC, SG, WAF)	Protect networks and compute	Protect network and compute resources
Perlindungan Data	Protect data at rest and in transit	Data classification and protection	Protect data at rest and in transit
Respons Insiden	Prepare for security events	Incident response	Manage security incidents

K. Ringkasan Konsep Kunci

Konsep	Poin Utama yang Wajib Diingat
Model Layanan Cloud	IaaS > PaaS > SaaS: semakin ke kanan, semakin sedikit kontrol pelanggan atas keamanan infrastruktur
Shared Responsibility	CSP aman infrastrukturnya, bukan datamu. Data, IAM, enkripsi, konfigurasi = tanggung jawab pelanggan
IAM Cloud	Least privilege WAJIB. MFA untuk semua akun. Gunakan Role bukan long-term key. Aktifkan audit log
CASB	Solusi visibilitas & kontrol untuk penggunaan cloud. 4 pilar: Visibility, Compliance, Data Security, Threat Protection
Enkripsi Cloud	CSP-Managed < Customer-Managed (KMS) < Customer-Provided < Client-Side. Makin besar kontrol, makin besar tanggung jawab
DLP	Cegah data sensitif keluar tanpa otorisasi. 4 jenis: Network, Endpoint, Cloud, Email DLP. Mulai dari Monitor, baru Block
Container Security	4C: Cloud-Cluster-Container-Code. Jangan root, scan image, secrets management, network policy, immutable FS

CSPM

Audit konfigurasi cloud otomatis. Misconfiguration terbesar: bucket publik, MFA mati, log mati, IAM berlebih

L. Latihan & Tugas

Soal Diskusi (In-Class)

8. Sebuah startup menggunakan AWS S3 untuk menyimpan data pelanggan. Developer baru tidak sengaja mengonfigurasi bucket menjadi public. Berdasarkan Shared Responsibility Model, siapa yang bertanggung jawab atas insiden ini? Bagaimana mencegahnya?
9. Jelaskan perbedaan antara Customer-Managed Keys (CMK) dan Client-Side Encryption di cloud. Kapan sebaiknya menggunakan Client-Side Encryption meskipun lebih kompleks untuk diimplementasikan?
10. Tim DevOps Anda ingin menjalankan container sebagai root karena "lebih mudah untuk instalasi dependency." Apa risiko keamanan spesifik yang ditimbulkan? Bagaimana cara mengatasi kebutuhan mereka tanpa mengorbankan keamanan?
11. Sebuah perusahaan menggunakan 15 layanan SaaS berbeda (Slack, Salesforce, Dropbox, dll.) untuk operasional. Bagaimana CASB dapat membantu mengamankan lingkungan ini? Jelaskan mode deployment yang paling tepat dan mengapa.
12. Apa perbedaan antara CASB, CSPM, dan CWPP (Cloud Workload Protection Platform)? Apakah sebuah organisasi perlu ketiganya, atau bisa memilih salah satu?

Tugas Lab — Konfigurasi IAM Cloud

TUGAS LAB

Menggunakan akun AWS Free Tier / Azure for Students / GCP Free Tier (pilih salah satu):

1. Buat IAM User baru (jangan gunakan root account)
2. Aktifkan MFA pada akun yang dibuat
3. Buat IAM Policy least-privilege hanya untuk: membaca objek dari satu S3 bucket / Blob Storage tertentu
4. Lampirkan policy tersebut ke user. Verifikasi user DAPAT membaca dari bucket tersebut tapi TIDAK DAPAT membuat, menghapus, atau mengakses bucket lain
5. Aktifkan CloudTrail / Activity Log dan tunjukkan log aktivitas IAM yang sudah dibuat
6. Buat laporan singkat: screenshot setiap langkah + penjelasan konsep keamanan yang diterapkan

Jika tidak memiliki akun cloud, gunakan LocalStack (emulator AWS lokal) atau playground di labs.play-with-docker.com

M. Referensi & Bacaan Lanjutan

- AWS Shared Responsibility Model: aws.amazon.com/compliance/shared-responsibility-model
- AWS Well-Architected Framework — Security Pillar: docs.aws.amazon.com/wellarchitected
- Azure Security Benchmark: docs.microsoft.com/en-us/security/benchmark/azure
- Google Cloud Security Best Practices Center: cloud.google.com/security/best-practices
- CIS Benchmarks for Cloud: cisecurity.org/benchmark (AWS, Azure, GCP, Kubernetes)
- NIST SP 800-144: Guidelines on Security and Privacy in Public Cloud Computing
- CSA Cloud Controls Matrix (CCM): cloudsecurityalliance.org/research/cloud-controls-matrix
- OWASP Docker Top 10: owasp.org/www-project-docker-top-10
- Kubernetes Security Best Practices: kubernetes.io/docs/concepts/security
- Falco — Runtime Security for Cloud Native: falco.org